

ArnoBot — Security Launch Checklist

Versie: 1.0 | Datum: 26 juni 2026

Al geregeld (bestaande stack)

Clerk authenticatie — LinkedIn OAuth, geen eigen wachtwoordopslag

Supabase RLS — Row Level Security actief op alle tabellen

Service role key server-side — nooit blootgesteld aan de client

Admin-toegang — httpOnly cookie + aparte roteerbare sleutel

CRON_SECRET — alle cron-routes vereisen geheime header

Vercel Edge — DDoS-bescherming op netwerkniveau ingebouwd

HTTPS — Vercel dwingt SSL af op alle domeinen

Middleware sessievalidatie — Clerk JWT gecontroleerd op alle beveiligde routes

◀ Nieuw toegevoegd (deze sessie)

Auth & IDOR-fixes

IDOR gedicht op /api/pdf-data — userId uit sessie, niet uit query param

/api/bot/verfijn — Clerk auth toegevoegd (was volledig open)

/api/bot/team/join GET — vereist nu login

Manager-check in /api/bot/team/1on1 — zelfde team vereist

Rate Limiting

Hoofdchat: max 5 verzoeken/min per IP (via Supabase logtabellen)

Admin-login: max 10 pogingen/15 min per IP + 500ms vertraging

Team join: maximaal 25 leden per team

Security Headers

next.config.ts bijgewerkt: X-Frame-Options, HSTS, CSP, Referrer-Policy, Permissions-Policy

poweredByHeader: false (verbergt Next.js versie)

Input Sanitatie & Injectiebeveiliging

detectPromptInjection() — 14 regex-patronen (NL + EN) in hoofdchat

Berichtlengte-limieten: chat max 4.000 tekens, history max 40 items

Sparring-limieten: bericht max 2.000, context max 500, history max 40

Feedback max 2.000 tekens, gesanitized voor Telegram (injection voorkomen)

E-mailvalidatie op admin-invite en coachEmail in share-overview

name-parameter in 1on1 afgekapt op 100 tekens

Middleware Hardening

Scanner-blokkering: .env, .git, wp-admin, phpMyAdmin, xmlrpc.php etc. ' 404

Admin route beschermd via isAdminRoute matcher in middleware

Foutafhandeling (geen info-lek)

6 routes gecorrigeerd: interne foutmeldingen niet meer teruggegeven aan client

Supabase/Resend/Anthropic fouten worden alleen server-side gelogd

Timeouts

maxDuration ingesteld op 12 AI-routes (15 t/m 60 seconden)

Afhankelijkheden

npm audit: 39 kwetsbaarheden ' 13 (alle resterende zijn build-time CLI-tools)

Sanity CMS bijgewerkt van v3 naar v6 (actueel)

Next.js, Clerk, jspdf en ws bijgewerkt (runtime-kwetsbaarheden verholpen)

⇒Pre-launch acties (handmatig)

Vercel Dashboard

Vercel Firewall aanzetten: Project Settings ' Security ' Enable Firewall

Bot Filter aanzetten in Vercel Security

Rate limiting instellen in Vercel Firewall UI (aanvullend op code-level)

NEXT_PUBLIC_APP_URL=https://arno.bot controleren in Vercel env vars

Supabase

RLS policies audit: run `SELECT * FROM pg_policies;` in Supabase SQL editor

Controleer dat anon rol GEEN insert/update/delete heeft op gevoelige tabellen

Database backups aanzetten (Supabase Pro of Point-in-Time Recovery)

Controleer dat SUPABASE_SERVICE_ROLE_KEY nergens in client-side code lekt

Clerk

Productie Clerk applicatie in gebruik (niet development instance)

Webhook endpoint gevalideerd met `CLERK_WEBHOOK_SECRET`

Session duration instellen: Settings ' Sessions ' Token lifetime

Git / Code

.gitignore bevat: `.env, .env.local, .env.*.local`

Run: `git log --all --full-history -- "**/.env*" — check geen secrets gecommit`

Run: `grep -r "sk-ant-" . --include="*.ts" --include="*.tsx" — geen hardcoded keys`

Run: `grep -r "service_role" . --include="*.ts" --include="*.tsx" — alleen server routes`

Admin sleutel

ARNOBOT_ADMIN_KEY roteren naar sterke willekeurige string (post-launch)

Genereer nieuwe waarde: `openssl rand -hex 32`

Bijwerken in Vercel env vars

⇒Security headers testen

Na deployment, test op securityheaders.com en observatory.mozilla.org. Target: grade A of A+.

Verwachte headers:

```
X-Frame-Options: DENY
X-Content-Type-Options: nosniff
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: aanwezig
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: aanwezig
X-Powered-By: afwezig (goed!)
```

⇒DDoS scenario's — wat beschermt wat?

Aanval type	Bescherming
Volumetrisch (flood)	Vercel Edge Network (automatisch)
API hammering (chat)	Rate limiting: 5 req/min per IP
Slow Loris	Vercel timeout + maxDuration op alle AI-routes
SQL-injectie	Supabase parameterized queries + Row Level Security
XSS	CSP headers + input sanitatie
Prompt injection	detectPromptInjection() in hoofdchat (14 patronen)
Admin brute force	Rate limit + 500ms vertraging + httpOnly cookie
Scanner bots	Middleware bot detection + 404 response
.env / git scan	Middleware blocked paths + Vercel redirects
IDOR	userId altijd uit sessie, nooit uit request params
Credential stuffing	LinkedIn OAuth via Clerk (geen wachtwoord mogelijk)

⇒Na bedrijfsoprichting

Supabase DPA tekenen

Clerk DPA URL opslaan

Vercel DPA URL opslaan

Anthropic DPA URL opslaan

ArnoBot DPA invullen (KvK + vestigingsadres)

Privacypagina artikel 1 updaten met KvK-nummer

Anthropic cost alerts instellen in Anthropic console

Laatste update: 26 juni 2026 — ArnoBot security review